https://github.com/vlamirvieira/SGSI-norma-ISO27001/edit/main/README.md

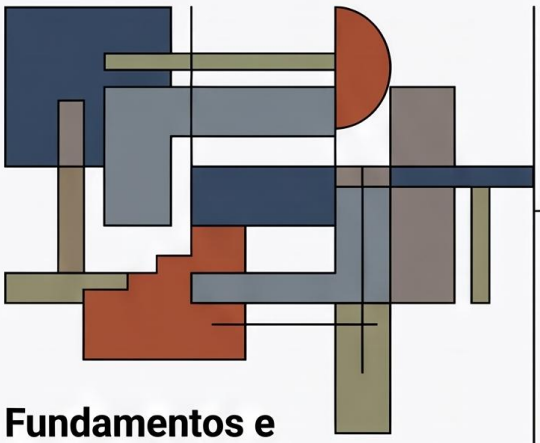
Roadmap de Implantação da ISO 27001: Sequência Estratégica do SGSI

A norma ISO/IEC 27001 estabelece diretrizes formais baseadas na gestão de riscos para assegurar a confidencialidade, integridade e disponibilidade dos ativos informacionais. A implementação segue um roteiro estruturado de governança, operação, monitoramento e validação externa, sustentado por um rigoroso controle documental.



Cultura de Cibersegurança e Fundamentos da ISO 27001

A segurança da informação segundo a ISO 27001 transcende controles tecnológicos: trata-se de um compromisso estratégico que envolve a gestão de riscos, o engajamento da liderança e a transformação da cultura organizacional no dia a dia.



Fundamentos e Gestão de Riscos

Tríade CID: Base da Segurança

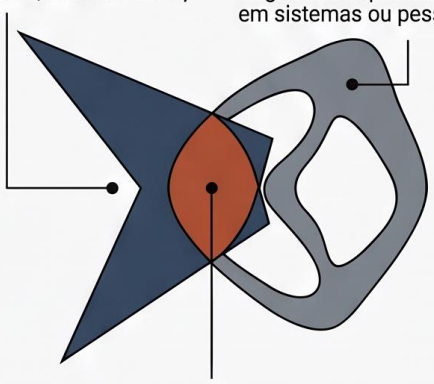
C — Confidencialidade
Preserva a Confidencialidade (acesso autorizado).

I — Integridade
Integridade (exatidão dos dados).

D — Disponibilidade
Disponibilidade (acesso sob demanda).

Ameaça
Ameaça é o agente/evento nocivo;

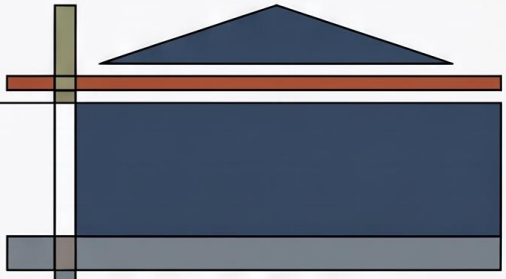
Vulnerabilidade
Vulnerabilidade é a fragilidade explorável em sistemas ou pessoas.



A Origem do Risco

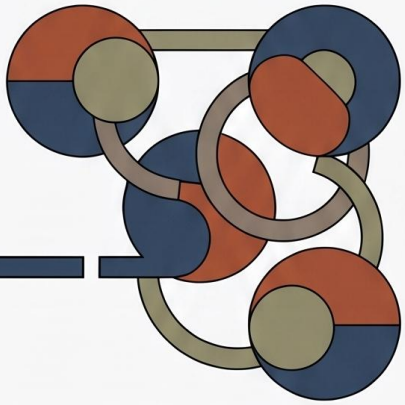
O risco resulta da probabilidade de uma ameaça explorar uma vuinerabilidade com determinado impacto.

Governança e Engajamento Humano



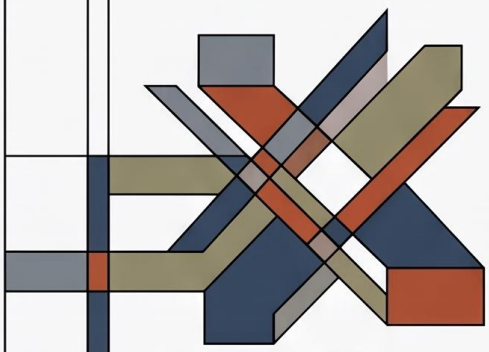
Papel da Alta Direção

A liderança deve patrocinar o SGSI, alinhar políticas ao negócio e prover recursos formais.



Conscientização e Capacitação Contínua

Treinamentos periódicos e simulações transformam regras teóricas em comportamentos seguros cotidianos.



Responsabilidade Transversal

A segurança não é exclusiva da TI, mas um dever compartilhado por todos os setores.

Gemini Notebook